



Tecnológico Nacional de México

Instituto Tecnológico de Chiná

Nombre de la carrera:

Ingeniería en Informática.

Nombre de la asignatura:

Programación cliente - servidor.

Semestre y grupo:

7AI

Actividad:

Registro de práctica #3 Modelo de Arquitectura y Confianza.

Nombre del alumno:

Aaron Jesús Eloy Aguilar León.

Chi Chablé Miguel Eduardo.

Ek Noh Edgar Ernesto.

Nombre del docente:

Jenner Noe Che Méndez.

Lugar y fecha:

San Francisco de Campeche, Campeche a 03 de Octubre de 2026.

Objetivo

Diseñar y especificar la arquitectura de software para el Sistema Integral Académico (SIA-ITC) mediante el enfoque API-First y el modelo C4, delimitando zonas de confianza, flujos de información y controles de seguridad, con el fin de garantizar una plataforma escalable, mantenible y segura que optimice la gestión de la información académica institucional.

1.- Nombre del sistema.

SIA-ITC (Sistema Integral Académico del Instituto Tecnológico de Chiná).

2.- Descripción del problema.

La institución educativa enfrenta ineficiencias en la gestión académica debido al registro disperso de información, procesos manuales en la captura de calificaciones por parte de los docentes y saturación en los periodos de consulta de horarios y boletas de calificaciones, esta situación provoca cuellos de botella en los servidores locales, falta de trazabilidad en la modificación de actas y un riesgo potencial en la integridad de los datos académicos ante accesos no autorizados.

Se requiere diseñar una arquitectura cliente-servidor contemporánea que centralice la información, garantice la separación de responsabilidades, exponga servicios seguros orientados a API y asegure la alta disponibilidad mediante un modelo escalable.

3.- Actores.

Estudiante: Usuario final que consulta su carga académica, horarios de clase, calificaciones parciales/finales e historial académico.

Docente: Usuario operativo que gestiona los grupos asignados, captura calificaciones por parcial y emite actas de evaluación.

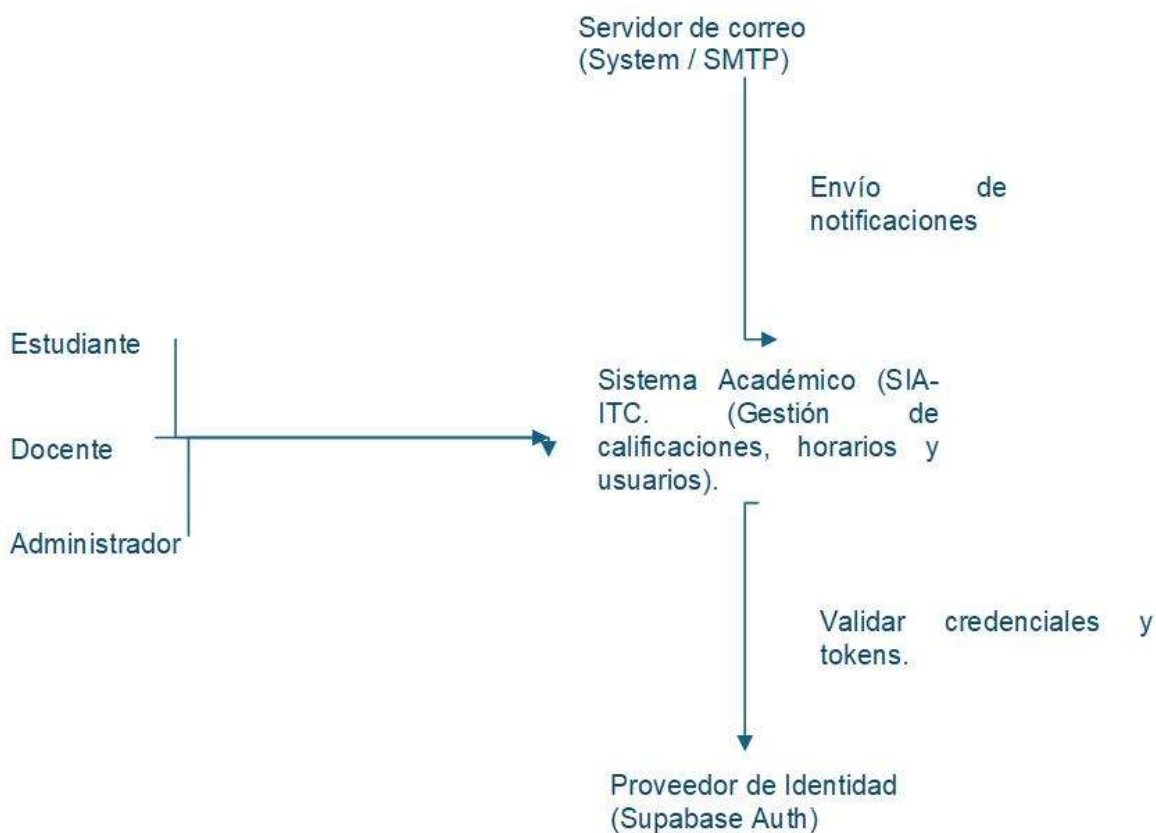
Administrador / Control Escolar: Usuario de gestión que administra el catálogo de asignaturas, asigna la plantilla docente, registra estudiantes y realiza cierres de periodos escolares.

4.- Sistemas Externos.

Proveedor de Identidad / Autenticación (Supabase Auth): Gestiona el inicio de sesión seguro, cifrado de credenciales y la emisión de tokens de acceso (JWT).

Servidor de Notificaciones (SMTP / SendGrid): Envía correos automáticos de confirmación, notificaciones de avisos académicos y envío de boletas en PDF.

5.- Diagrama C4 de contexto (C1).



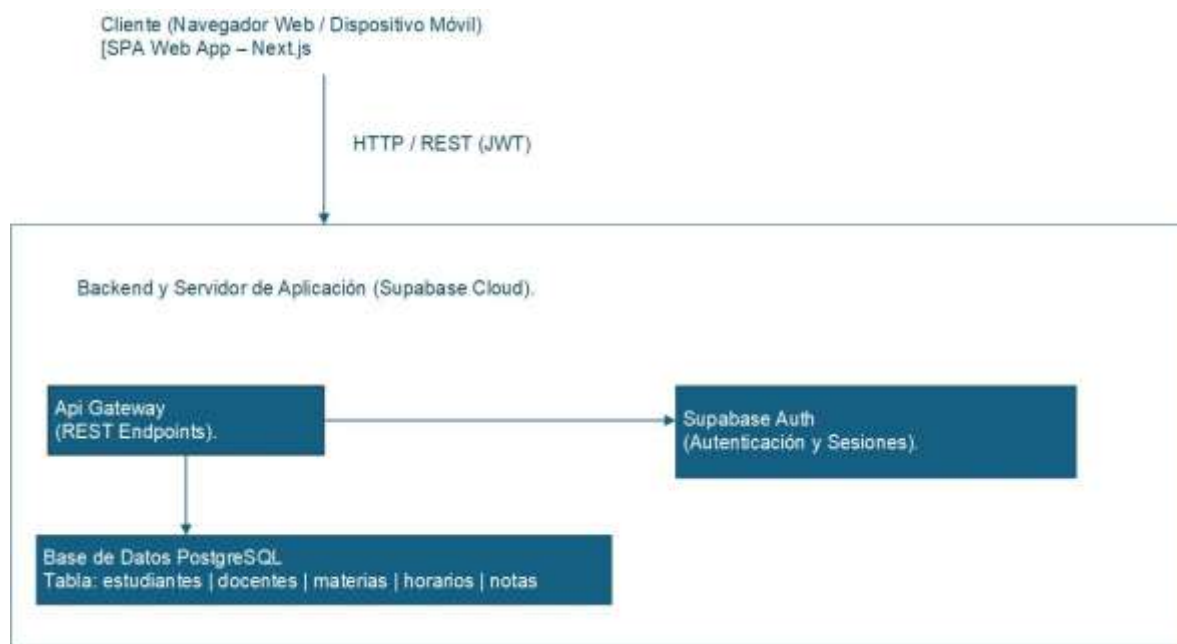
6.- Lista de contenedores.

Frontend Web App (Next.js / React): Aplicación de una sola página (SPA) que ofrece las interfaces dinámicas para estudiantes, docentes y administradores

API Gateway / Backend Service (PostgREST / Supabase API): Capa intermedia de microservicios que expone endpoints REST, valida la lógica de negocio y autoriza peticiones mediante tokens.

Database (PostgreSQL): Sistema gestor de base de datos relacional para el almacenamiento persistente de alumnos, asignaturas, horarios, inscripciones y calificaciones.

7.- Diagrama C4 de contenedores (C2).



8.- Tabla de responsabilidades.

Contenedor.	Responsabilidad principal.	Tecnologías sugeridas.
Frontend Web App	Capturar entradas del usuario, gestionar el estado de sesión local y renderizar interfaces de horarios y calificaciones.	Next.js, React, Tailwind CSS.

API Gateway / Backend.	Procesar solicitudes HTTP, verificar permisos del token JWT, aplicar reglas de negocio e intermediar con la base de datos.	Node.js / PostgREST (Supabase).
Base de Datos.	Garantizar la persistencia, integridad referencial de los datos académicos y aplicar seguridad a nivel de fila (RLS).	PostgreSQL.

9.- Tres flujos de información.

Flujo 1: Consulta de Carga y Horarios de Clase:

- El estudiante inicia sesión y solicita su horario.
- El cliente realiza una petición a la API.
- La API consulta la base de datos realizando un cruce de datos (JOIN) entre las tablas inscripciones, materias y horarios, retornando la información estructurada al usuario.

Flujo 2: Carga y Captura de Calificaciones:

- El docente selecciona la asignatura y el grupo a evaluar.
- Ingresa las notas parciales y envía la solicitud a la API.
- El backend valida el rol de docente, la ventana de tiempo activa para la carga de notas y persiste los cambios en la tabla.

Flujo 3: Emisión de Boleta y Cierre Escolar:

- El estudiante o el administrador solicita el reporte de calificaciones finales.

- El sistema calcula el promedio ponderado del periodo, consulta el historial académico y genera la respuesta con el estado del alumno (Aprobado/Acredita/Sancionado).

10.- Endpoints preliminares.

Método.	Endpoint.	Descripción.
POST	/api/v1/auth/login	Autenticación de usuario y generación de token JWT.
GET	/api/v1/estudiantes/{id}/horario	Consulta de la retícula y horarios del estudiante.
GET	/api/v1/estudiantes/{id}/boleta	Obtención de calificaciones e historial académico.
POST	/api/v1/calificaciones	Carga de notas por asignaturas y grupo.
PUT	/api/v1/calificaciones/{id}	Actualización / corrección de una nota capturada.

11.- Límites de confianza.

- Zona No Confiable (Frontend / Cliente): Navegador web ejecutado en los dispositivos de los usuarios. Cualquier dato o entrada proveniente de este entorno se considera potencialmente malicioso y se somete a validación estricta.
- Zona de Tránsito (Red / Transport Layer): Conexión pública a través de Internet protegida bajo el protocolo HTTPS/TLS 1.3 con encabezados Authorization: Bearer <JWT>.
- Zona Confiable (Backend / Database): Servidor centralizado y base de datos donde se ejecuta la lógica de negocio y las políticas Row Level Security

(RLS) de PostgreSQL, impidiendo que un estudiante pueda leer o alterar registros de otros usuarios o docentes.

12.- Datos sensibles.

Datos Sensibles / Personales: Correo institucional, contraseña, número de matrícula, CURP, nombre completo.

Datos Críticos de Negocio: Calificaciones finales, promedio acumulado, actas de evaluación y estatus académico.

13.- Clasificación de datos.

Dato.	Clasificación.	Justificación.
Contraseña / Tokens.	Restringido / Crítico.	Una filtración compromete por completo la seguridad de las cuentas.
Calificaciones / Actas.	Confidencial.	Datos académicos privados protegidos por las normativas institucionales de privacidad.
Oferta de Materias / Horarios.	Interno / Público.	Información operativa de la institución que no vulnera la privacidad de los usuarios.

14.- Controles presupuestos.

1.- Cifrado en Tránsito y Reposo: Implementar HTTPS/TLS en todas las comunicaciones del sistema y cifrado AES-256 para los datos almacenados en reposo en la base de datos.

2.- Control de Acceso basado en Roles y Filas (RBAC + RLS): Configuración de políticas de seguridad en la base de datos para restringir el acceso a nivel de fila según el ID de usuario autenticado.

3.- Hashing Seguro de Credenciales: Algoritmo Argon2 o Bcrypt para el almacenamiento seguro de contraseñas sin posibilidad de descifrado inverso.

15.- Conclusión.

La arquitectura diseñada para el Sistema Integral Académico (SIA-ITC) resuelve de forma integral las ineficiencias del modelo tradicional mediante la adopción de un enfoque API-first y la separación de responsabilidades.

La delimitación de zonas de confianza y la integración de controles como TLS, JWT y Row Level Security en la base de datos garantizan la confidencialidad, integridad y disponibilidad de la información académica ante picos de demanda durante los periodos de carga de calificaciones y consulta de horarios.

Cuestionario.

1.- ¿Por qué este actor aparece en el contexto?

Aparecen los actores principales (Estudiante, Docente y Administrador) porque representan las diferentes identidades que interactúan directamente con las funcionalidades del sistema (consultar horarios, capturar calificaciones o gestionar la oferta académica).

Su inclusión en el C1 permite visualizar los límites y permisos que cada rol tiene frente al sistema.

2.- ¿Por qué este elemento es un sistema externo?

Tanto Supabase Auth como el Servidor SMTP (SendGrid) se consideran sistemas externos porque son servicios administrados fuera del alcance de la lógica de negocio principal del sistema.

Aparte se comunican mediante protocolos estándar (HTTPS/REST y SMTP) para resolver tareas especializadas (autenticación y envío de correo) sin sobrecargar la infraestructura propia.

3.- ¿Por qué separaron frontend y backend?

Para aplicar el principio de separación de responsabilidades (Separation of Concerns).

Esto permite que la interfaz gráfica (Next.js) se ejecute de forma independiente en el cliente sin estar acoplada al código del servidor, facilitando el desarrollo en paralelo, mejorando la mantenibilidad, reutilizando APIs para futuros clientes y escalando el backend por separado.

4.- ¿Por qué el cliente no accede directamente a la base de datos?

Por seguridad y control de negocio, ya que al acceder directamente expondría las credenciales de la base de datos en el cliente, permitiendo que usuarios maliciosos ejecuten consultas no autorizadas o modifiquen calificaciones directamente sin pasar por las reglas de validación y auditoría de la API.

5.- ¿Qué datos cruzan Internet?

Peticiones HTTP con payloads JSON conteniendo credenciales de inicio de sesión, parámetros de consulta (IDs de estudiantes, asignaturas), tokens de autorización (JWT) y respuestas estructuradas con calificaciones, horarios y boletas académicas.

6.- ¿Dónde colocaron el límite de confianza?

Entre la Aplicación Web (Frontend en la zona pública no confiable) y el API Gateway / Base de Datos (Backend en la zona confiable). Todo lo que cruza esa frontera a través de la red debe ser validado e inspeccionado mediante HTTPS/TLS y tokens de autorización.

7.- ¿Cuál es el dato más sensible?

Las credenciales de acceso (contraseñas) e identificadores de sesión/tokens JWT, ya que su suplantación permitiría vulnerar identidades y alterar datos académicos críticos como las calificaciones finales.

8.- ¿Qué ocurre si alguien roba el token?

El atacante podría realizar solicitudes suplantando la identidad del usuario durante el tiempo de vida útil que tenga dicho token.

Para mitigar esto, se utilizan tokens de corta duración, transmisión exclusiva por HTTPS, banderas HttpOnly/Secure en cookies o encabezados, y la posibilidad de revocar la sesión desde el backend.

9.- ¿Dónde se valida el rol?

El rol se valida en el Backend / API Gateway al decodificar y verificar la firma del token JWT en cada petición, y de forma definitiva en la Base de Datos PostgreSQL mediante las políticas de Row Level Security (RLS), nunca se valida únicamente en el frontend.

10.- ¿Qué servicio externo recibe información?

El Servidor SMTP / SendGrid recibe las direcciones de correo institucional y el contenido del mensaje (boletas/avisos) para su distribución, mientras que Supabase Auth recibe las credenciales del usuario durante la autenticación.

11.- ¿Qué datos no deberían enviarse a ese servicio?

No deben enviarse contraseñas en texto plano, tokens de acceso de administración, ni datos académicos personales no indispensables (como la retícula completa o el historial de calificaciones del estudiante) al servicio de correo externo.

12.- ¿Cómo cambiaría la arquitectura si existiera una app móvil y una web?

La arquitectura no cambiaría en su núcleo (Backend) gracias al enfoque API-First. Solo se añadiría un contenedor adicional en la capa de cliente (App Móvil en Flutter/React Native) que consumiría los mismos endpoints REST y la misma infraestructura de autenticación que la aplicación Web SPA.